

Bildiri Özeti (Conference Abstract)

ACL Tasarım Hataları: Ağ ve Sistem Güvenliğinde Yapılandırma Kaynaklı Zafiyet Analizi

Yazar: Emre Duyar **Kurum:** İstanbul Aydın Üniversitesi , Yönetim Bilişim Sistemleri Bölümü **Sunum Türü:** Sözlü Bildiri

Bu çalışmamda, Erişim Kontrol Listesi (ACL) yapılarındaki tasarım hatalarını; yazılım güvenliği, web uygulama güvenliği, işletim sistemi erişim kontrolü ve kurumsal ağ sızma testi literatürü çerçevesinde ele almaktayım. Çalışmamamın temel amacı, farklı katmanlarda ortaya çıkan ACL kaynaklı zafiyetlerin ortak paydalarını ortaya koymak ve bu hataların nasıl tespit edilebileceğini tartışmaktır.

İncelediğim kaynaklar üzerinden elde edilen bulgular birkaç kritik noktada yoğunlaşmaktayım. Of (2019) ve Kanmaz (2023), OWASP Top 10 verileri üzerinden Kırık Erişim Kontrolü'nün (Broken Access Control) 2017 ile 2021 listeleri arasında beşinci sıradan birinci sıraya yükseldiğini göstermektedir; bu eğilim, söz konusu zafiyet kategorisinin ne ölçüde yaygınlaştığının somut bir göstergesi olmaktadır. Bozan ve Uzun (2023) ise erişim kontrol modellerini teorik düzeyde ele alarak DAC (İsteğe Bağlı Erişim Kontrolü) yapısının kurumsal ortamlarda yönetimsel açıdan nasıl kırılgan hale gelebildiğini ortaya koymaktadır. Şentürk ve Irmak (2024) tarafından yürütülen uygulamalı sızma testinde ise Windows Aktif Dizin ortamında tek bir hatalı ACL girişinin — "Generic All" yetkisinin yanlış atanmasının — standart bir kullanıcıyı etki alanı yöneticisi konumuna taşıyabildiği belgelenmiştir. Ceylan ve Kavut (2025) bu bulguları metodolojik bir çerçeveye oturtarak OWASP, PTES ve NIST ölçünleri aracılığıyla erişim kontrolü açıklarının sızma testlerinde nasıl sistematik biçimde saptanabileceğini ve CVSS v3.1 ile nasıl risk puanlamasına tabi tutulabileceğini göstermektedir.

Çalışmam, ACL tasarım hatalarının yalnızca teknik bir yapılandırma sorunu olmadığını; kurumsal ağlarda ve yazılım sistemlerinde erişim haklarının "en az ayrıcalık" ilkesiyle yönetilmemesi ile varsayılan sistem ayarlarına duyulan aşırı güvenin sistemik bir zafiyet kaynağı oluşturduğunu savunmaktadır. Bu doğrultuda periyodik sızma testleri ve erişim kontrolü politikalarının düzenli gözden geçirilmesi en temel koruyucu önlemler olarak öne çıkmaktadır.

Anahtar Kelimeler: Erişim Kontrol Listesi, ACL, Broken Access Control, Güvenlik Yapılandırması, Sızma Testi, Active Directory, OWASP